

ANRH Publications

Audit de dette technique

10 juillet 2026

<https://pub.anrh.fr> (staging)

6 dettes CRITIQUES corrigées

6 SÉCURITÉ + 6 QUALITÉ + SEO corrigés — sections 1 à 4

1. Correctifs critiques appliqués

Les points suivants ont été corrigés le 10/07/2026. Ils ne nécessitent plus d'action immédiate.

#1 bin/reset-client-access.php

RÉSOLU

Problème : Mots de passe en dur dans le dépôt.

Action : Mots de passe générés via CLI/env — plus de secrets commités.

#2 tools/migrate-prestashop.php

RÉSOLU

Problème : Script migration accessible via HTTP.

Action : Exécution CLI uniquement (HTTP 403).

#3 inc/b2b/tools.php

RÉSOLU

Problème : Export CSV panier sans contrôle prix B2B.

Action : Export réservé aux clients connectés et approuvés.

#4 inc/b2b/tools.php

RÉSOLU

Problème : Compateur AJAX sans nonce.

Action : check_ajax_referer + nonce JS ajoutés.

#5 .github/workflows/

RÉSOLU

Problème : Déploiement sans validation préalable.

Action : Job valide (lint PHP, grep secrets) avant FTP.

#6 deploy-staging.yml

RÉSOLU

Problème : Déploiement non vérifié après envoi.

Action : Smoke test HTTP post-deploy + exclusion bin/tools du bundle.

2. Sécurité applicative — corrigée

Les 6 points de la section « Sécurité applicative (restant) » ont été corrigés le 10/07/2026.

#7 inc/b2b/pricing.php

RÉSOLU

Problème : Calcul prix HT sans gate centralisé.

Action : anrhpublish_price_visible_context() intégré dans get_unit_price_ht().

#8 inc/b2b/client-pro.php

RÉSOLU

Problème : Compte sans meta = approuvé par défaut.

Action : Statut pending par défaut + migration comptes existants.

#9 inc/contact-form.php

RÉSOLU

Problème : Formulaire devis sans rate limiting ni CAPTCHA.

Action : Throttling IP + captcha arithmétique.

#10 inc/newsletter.php

RÉSOLU

Problème : Inscription AJAX sans limitation.

Action : Rate limit par IP et par e-mail.

#11 inc/b2b/quotes.php

RÉSOLU

Problème : PDF devis : capability edit_posts trop large.

Action : Accès restreint via edit_post sur le devis.

#12 inc/gdpr.php

RÉSOLU

Problème : Bandeau cookies sans blocage scripts.

Action : CMP minimal : blocage scripts analytics + activation au consentement.

3. Qualité de code et architecture — corrigée

Les 6 points de la section « Qualité de code et architecture » ont été corrigés le 10/07/2026.

#13 tests/ + composer.json

RÉSOLU

Problème : Aucun test automatisé.

Action : PHPUnit : auth B2B, panier devis, PDF devis (CI).

#14 assets/js/src/ + Vite

RÉSOLU

Problème : Monolithe main.js 2700+ lignes.

Action : 14 modules ES + build Vite (fallback Python).

#15 functions.php

RÉSOLU

Problème : 10+ CSS sur toutes les pages.

Action : Enqueue conditionnel : vitrine, pages, B2B par contexte.

#16 inc/catalogue-search.php

RÉSOLU

Problème : Requêtes illimitées par recherche.

Action : Limite 500 résultats, requête catégories groupée, cache transient.

#17 inc/product-colors/

RÉSOLU

Problème : God-module 1200+ lignes.

Action : Scindé en taxonomy, admin-term, admin-product, frontend.

#18 inc/demo-data.php

RÉSOLU

Problème : Données démo au switch thème.

Action : Désactivé hors local/development (WP_ENVIRONMENT_TYPE).

4. SEO et protection staging — corrigés

SEO avancé (production uniquement) et blocage d'indexation staging renforcé le 10/07/2026. Voir section 5 pour les procédures de déploiement.

#19 inc/seo.php

RÉSOLU

Problème : SEO basique, pas de schema ni noindex facettes.

Action : Meta OG/Twitter, canonical, JSON-LD Product/LocalBusiness, sitemap filtré, robots.txt prod.

#20 mu-plugins/anrh-staging-gate.php

RÉSOLU

Problème : Staging indexable par les moteurs.

Action : Gate HTTP + noindex + sitemaps off + ajax/xmlrpc/feeds bloqués.

#21 deploy-ovh/.htaccess

RÉSOLU

Problème : Pas de X-Robots-Tag global staging.

Action : Header noindex sur tout le staging (fichiers statiques inclus).

#22 inc/gdpr.php

RÉSOLU

Problème : Analytics actifs sur staging.

Action : Bandeau cookies et scripts analytics désactivés en staging.

5. Mise en staging (pub.anrh.fr)

Procédure actuelle — environnement de prévisualisation OVH. Le site n'est pas public : gate HTTP + noindex multi-couches.

Checklist staging (état attendu)

- Push sur master → workflow « Deploy staging OVH (pub.anrh.fr) » (validate + FTP + smoke test).
- Secrets GitHub : OVH_FTP_*, OVH_DB_PASSWORD, STAGING_GATE_USER, STAGING_GATE_PASSWORD.
- wp-config généré : WP_ENVIRONMENT_TYPE=staging, ANRH_STAGING_GATE=true.
- mu-plugin anrh-staging-gate.php actif (accès HTTP Basic-like par cookie).
- .htaccess : X-Robots-Tag noindex + AddDefaultCharset UTF-8.
- SEO désactivé sur staging : pas d'OG, pas de JSON-LD (inc/seo.php).
- Vérifications : site en 401/403 sans auth ; curl -I → X-Robots-Tag ; robots.txt → Disallow: /.

6. Mise en production

À exécuter avant l'ouverture au public. Fichiers clés : `deploy-ovh/wp-config.template.php`, `deploy-ovh/.htaccess`, `wp-content/mu-plugins/anrh-staging-gate.php`, `.github/workflows/deploy-staging.yml`.

Checklist bascule production

- Créer wp-config production : `WP_ENVIRONMENT_TYPE=production`, `ANRH_STAGING_GATE=false`.
- Retirer le mu-plugin `anrh-staging-gate.php` du bundle de déploiement.
- Remplacer `deploy-ovh/.htaccess` : supprimer le bloc X-Robots-Tag staging (garder HTTPS + UTF-8).
- Sels WordPress uniques (ne pas réutiliser ceux du template staging).
- Activer durcissement : `DISALLOW_FILE_EDIT`, `FORCE_SSL_ADMIN`, `WP_DEBUG=false`.
- Réglages WP → Lecture : décocher « Décourager l'indexation » (`blog_public=1`).
- Search Console : propriété + sitemap `https://.../wp-sitemap.xml`.
- Export DB local → staging → prod avec wp search-replace (URLs + serialized-safe).
- Vérifier charset DB `utf8mb4` et collation `utf8mb4_unicode_ci`.
- Retirer `staging-health.php` du webroot si encore présent.

Important : le workflow CI actuel déploie uniquement le staging. Prévoir un workflow ou un job manuel distinct pour la production (autre FTP, autre wp-config, sans gate).

7. Déploiement et infrastructure

#1 FTP OVH

Élevé

Problème : Protocole FTP en clair, déploiement non atomique.

Action : SFTP si disponible ; healthcheck (fait).

#2 deploy-staging.yml

Élevé

Problème : Fichiers orphelins non supprimés sur le serveur.

Action : Sync miroir ou nettoyage ciblé.

#3 staging-health.php

Moyen

Problème : Script diagnostic en webroot.

Action : Retirer après validation.

#4 export-staging-db.ps1

Moyen

Problème : Export DB manuel Windows uniquement.

Action : wp-cli search-replace cross-platform.

#5 README.md

Faible

Problème : Documentation partiellement obsolète.

Action : Aligner sur WP 7.0 et scope deploy.

8. Configuration et WordPress core

#6 wp-config.template.php

Élevé

Problème : Sels WordPress statiques dans le repo.

Action : Sels uniques par environnement via secrets.

#7 .gitignore

Élevé

Problème : WordPress core versionné (~5500 fichiers).

Action : Déployer le core via Composer/wp-cli.

#8 wp-config.template.php

Moyen

Problème : Pas de DISALLOW_FILE_EDIT, FORCE_SSL_ADMIN.

Action : Durcissement production.

#9 plugins/

Faible

Problème : Akismet inutile, UpdraftPlus lourd.

Action : Nettoyer les plugins.

9. Plan de remédiation

P1 — Important

- Sels WordPress uniques par environnement
- Export DB avec wp search-replace (serialized-safe)

P2 — Amélioration

- Retirer staging-health du deploy automatique
- Réduire le scope git (core WP hors repo)
- Étendre la couverture PHPUnit (intégration WP)
- PDF devis : police embarquée UTF-8 (au-delà de WinAnsi)

P3 — Confort

- Audit accessibilité WCAG 2.1 AA
- Internationalisation complète (.pot)
- hreflang + image OG dédiée 1200px